COMSATS University Islamabad
CYC386 – Secure Software Design and Development
Midterm Lab Exam – 1-Week DevSecOps Security Sprint (Fall 2026)

Protection Needs Elicitation

PNE Report with CIA Triad Mapping

Field	Detail
Project	MedVault – Secure Diagnostic Lab Report Portal
Team	MedVault
Member(s)	Zojaja Naveed (Fa23-bct-047) Tayyeba Usman (Fa23-bct-053)
Instructor	Engr. Muhammad Ahmad Nawaz
Repository	https://github.com/Zojaja-Naveed/MedicalVault
Date	30 October 2026

1. System Overview

MedVault lets patients upload diagnostic lab reports (`.lab` files issued by a lab), view them, compress them for download, and share them with their doctors. A native C component parses each report header to extract the patient name and check the lab's "verified" signature.

The system is built with Flask (Python), SQLite, and a C shared library (`libparser.so`) loaded through `ctypes`. Jira epic: **MV-1 (PNE & CIA Mapping)**.

Traceability: every protection need links to a threat (T-xx), a Jira issue (MV-xx) and, after remediation, the pull request that fixed it: **PNE → Threat → Jira issue → Fix PR → Test evidence**.

2. Stakeholders

Stakeholder	Interest in the system
Patient	Privacy of their medical reports; control over who sees them
Doctor	Reliable, untampered reports from their patients
Diagnostic Lab	Only reports it actually signed appear as "verified"
Operator / DevOps	Server stays secure and available
Attacker (misuse view)	Steal reports, forge verified reports, take over the server

3. Asset Inventory

ID	Asset	Type	Description
A1	Lab report files	Data	Uploaded .lab medical reports in the file store
A2	Report metadata	Data	Owner, patient name, verified flag, file path (SQLite)
A3	User credentials	Data	Usernames and password hashes
A4	Session cookies	Data	Flask signed session identifying the logged-in user
A5	Share permissions	Data	Which doctor may view which report
A6	Flask web application	Component	Handles login, upload, view, share, compress
A7	Native C parser (libparser.so)	Component	Parses the report header line
A8	SQLite database	Component	Stores A2, A3 and A5
A9	File store (uploads/, archives/)	Component	Stores A1 and compressed archives
A10	Audit log	Data	Record of security-relevant user actions
E1–E3	Patient, Doctor, Diagnostic Lab	External entity	Users of and inputs to the system

4. Misuse Cases (Attacker Perspective)

ID	Misuse case
MU-1	Attacker reads another patient's report by changing the report ID in the URL
MU-2	Attacker uploads a crafted report whose long patient name forges the "verified" stamp or crashes the parser
MU-3	Attacker injects shell commands through the archive name when compressing a report
MU-4	Attacker's website silently makes a logged-in patient share a report with the attacker
MU-5	Attacker frames MedVault in an invisible iframe and tricks the patient into clicking "Share"
MU-6	Attacker forges session cookies using a hard-coded secret key or abuses debug mode

5. Protection Needs and CIA Mapping

Each protection need is mapped to Confidentiality (C), Integrity (I) and/or Availability (A), and turned into a measurable security requirement (SR) that can be tested.

ID	Protection Need	Stakeholder	Assets	C	I	A	Measurable Security Requirement	Threat	Jira
PN-01	Only the owner and doctors explicitly shared with can read a report	Patient	A1, A2	✓			SR-01: Object-level authorization check on every report access; unauthorized IDs return 404	T-03	MV-16
PN-02	A report's "verified" stamp cannot be forged	Lab, Doctor	A2, A7		✓		SR-02: Parser rejects patient names of 32+ bytes; all native copies are bounded; library compiled with -fstack-protector-strong -D_FORTIFY_SOURCE=2	T-01	MV-14
PN-03	The server never executes commands supplied by users	Operator	A6, A9	✓	✓	✓	SR-03: No shell interpretation of user-controlled strings; archive names must match ^[A-Za-z0-9_-]{1,40}$	T-02	MV-15
PN-04	State-changing actions happen only when the user intends them	Patient	A5	✓	✓		SR-04: Every POST requires a valid per-session anti-CSRF token; session cookie SameSite=Strict	T-04	MV-17
PN-05	Users cannot be tricked into clicking hidden UI	Patient	A5, A6		✓		SR-05: All responses send X-Frame-Options: DENY and CSP frame-ancestors 'none'	T-05	MV-18
PN-06	A malformed upload cannot crash the service	Operator, all users	A6, A7			✓	SR-06: Malformed headers rejected with HTTP 400; upload size limited to 1 MB	T-01	MV-14
PN-07	Credentials and sessions are protected	All users	A3, A4	✓	✓		SR-07: Passwords hashed (Werkzeug scrypt/PBKDF2); secret key from environment; HttpOnly cookies; debug mode off	T-06, T-07	MV-13
PN-08	Security-relevant actions are attributable	Lab, Operator	A10		✓		SR-08: Log login, upload, share and compress with username and timestamp	T-08	MV-13

5.1 CIA Coverage Summary

Property	Protection Needs	What it protects in MedVault
Confidentiality	PN-01, PN-03, PN-04, PN-07	Medical reports, credentials and sessions are readable only by authorized users
Integrity	PN-02, PN-03, PN-04, PN-05, PN-07, PN-08	Verified stamps, share lists, server files and logs cannot be altered by attackers
Availability	PN-03, PN-06	Malformed uploads or injected commands cannot crash or disable the service